

BÁO CÁO NGÀY [14/09/2026]

Dự án: Hệ thống Dự báo Doanh số (Sales Forecast System)

Nhóm thực hiện: Cá nhân

Hôm trước: Khởi tạo cấu trúc backend ASP.NET Core 8 và chức năng đăng nhập cơ bản

Hôm nay: Xây dựng cơ sở dữ liệu, hoàn thiện xác thực JWT, phân quyền RBAC và API Danh mục sản phẩm

Mục tiêu: Hoàn thiện nền tảng dữ liệu cho bán hàng, kho và dự báo doanh số; xây dựng đăng nhập bằng email/mật khẩu BCrypt, đăng xuất có thu hồi phiên JWT; áp dụng quyền Admin, QuanLyKho và NhanVienBanHang; hoàn thiện API CRUD danh mục và kiểm thử đầy đủ trên Swagger.

I. Bảng Phân Công Khối Lượng Công Việc Trong Ngày

Hạng mục	Công việc
1. Thiết kế và triển khai cơ sở dữ liệu	- Phân tích cấu trúc API/Core/Infrastructure và mô hình đăng nhập hiện có. - Thiết kế 16 bảng cho người dùng, danh mục, sản phẩm, kho, nhập hàng, bán hàng, tồn kho và dự báo. - Tạo khóa ngoại, chỉ mục, ràng buộc, view, stored procedure và trigger bảo vệ dữ liệu. - Triển khai trực tiếp lên SQL Server Express, database SalesForecastingDB.
2. Hoàn thiện xác thực JWT và đăng xuất	- Đăng nhập bằng email và mật khẩu; chuẩn hóa email; kiểm tra BCrypt. - Tạo access token 15 phút gồm sub, jti, email, name và role. - Lưu phiên vào bảng PhienDangNhap; API logout thu hồi phiên hiện tại. - Từ chối token hết hạn, sai chữ ký, sai Issuer/Audience, đã thu hồi, tài khoản bị khóa hoặc thay đổi quyền.

Hạng mục	Công việc
3. Phân quyền RBAC	- Chuẩn hóa tên quyền thành Admin, QuanLyKho và NhanVienBanHang. - Thiết lập chính sách mặc định yêu cầu đăng nhập cho API. - Cả ba vai trò được xem danh mục; chỉ Admin được thêm, sửa và xóa. - Bảo vệ các API kiểm tra database và dữ liệu phát triển bằng quyền Admin.
4. API Danh mục sản phẩm	- Xây dựng GET danh sách, GET chi tiết, POST, PUT và DELETE theo chuẩn REST. - Kiểm tra tên bắt buộc, độ dài tên tối đa 100 ký tự, mô tả tối đa 500 ký tự. - Trả 409 khi trùng tên hoặc danh mục đang được sản phẩm sử dụng; trả 404 khi không tồn tại. - Ánh xạ entity DanhMuc bằng Entity Framework Core.
5. Kiểm thử, tài liệu và Git	- Xây dựng bộ kiểm thử tích hợp tạo và tự dọn dữ liệu tạm. - Kiểm tra đầy đủ 401, 403, 200, dữ liệu sai, trùng tên, không tồn tại và logout. - Kiểm thử trực tiếp trên Swagger UI và xác nhận schema Bearer token. - Viết tài liệu chạy/demo, tài liệu cơ sở dữ liệu; commit và push lên GitHub.

II. Chi Tiết Thực Hiện

+ Triển khai cơ sở dữ liệu SQL Server: Tạo database SalesForecastingDB trên SQL Server Express với cấu trúc dữ liệu phục vụ xuyên suốt nghiệp vụ bán hàng, kho và dự báo. Tồn kho được tính từ số GiaoDichKho thay vì lưu số dư trùng lặp. Các thủ tục xác nhận nhập hàng và hoàn tất đơn hàng dùng transaction, khóa theo kho và kiểm tra tồn trước khi xuất.

+ Hoàn thiện xác thực JWT: AuthService kiểm tra email, trạng thái tài khoản, trạng thái vai trò và mật khẩu BCrypt. JwtTokenService phát hành token ký HMAC SHA-256, thời hạn 15 phút, đồng thời tạo mã phiên jti lưu trong database.

II. Chi Tiết Thực Hiện (tiếp theo)

- + Xây dựng cơ chế đăng xuất có hiệu lực: API POST /api/auth/logout cập nhật ThuHoiLuc của phiên hiện tại. Mỗi request có token sẽ đối chiếu phiên với database. Token đã đăng xuất tiếp tục bị từ chối sau khi API khởi động lại, trong khi phiên khác của cùng người dùng vẫn hoạt động.
- + Áp dụng phân quyền RBAC: Chuẩn hóa vai trò có dấu trong database sang Admin, QuanLyKho và NhanVienBanHang. Các endpoint access-check được dùng để xác nhận đúng ma trận quyền: chưa đăng nhập trả 401, sai vai trò trả 403 và đúng vai trò trả 200.
- + Xây dựng API Danh mục: DanhMucController cung cấp năm endpoint RESTful. Ba vai trò có quyền đọc; chỉ Admin có quyền ghi. Dữ liệu đầu vào sử dụng Validation Attributes, chuẩn hóa khoảng trắng và dựa trên unique index để xử lý chính xác xung đột tên khi có request đồng thời.
- + Chuẩn hóa phản hồi lỗi: Dữ liệu không hợp lệ trả 400; không tìm thấy trả 404; trùng tên hoặc không thể xóa vì có sản phẩm trả 409; chưa xác thực trả 401; thiếu quyền trả 403. Các lỗi nghiệp vụ sử dụng ProblemDetails để Swagger hiển thị rõ nguyên nhân.
- + Kiểm thử tích hợp End-to-End: Chạy ứng dụng thật với SQL Server, tạo tài khoản ngẫu nhiên cho ba vai trò, đăng nhập và gửi request HTTP đến toàn bộ endpoint. Bộ kiểm thử đạt 69/69 trường hợp, gồm token sai/hết hạn/thu hồi, khóa tài khoản, đổi vai trò, CRUD danh mục và ma trận quyền.
- + Kiểm thử và bàn giao trên Swagger: Xác nhận giao diện có nút Authorize, endpoint login công khai và các endpoint bảo vệ hiển thị Bearer security. Thử trực tiếp đăng nhập, xem danh sách, thêm danh mục, dữ liệu sai, trùng tên và mã không tồn tại.
- + Quản lý mã nguồn: Hoàn thiện hướng dẫn chạy, báo cáo kỹ thuật và đẩy mã nguồn lên nhánh master tại GitHub repository SalesForecastSystem. Commit chức năng phân quyền và kiểm thử: a04530a.

Các hình dưới đây trình bày lại những kết quả HTTP đã được kiểm chứng trên Swagger và trong bộ kiểm thử tích hợp. Dữ liệu minh họa được tạo tạm thời và đã được xóa sau khi kiểm thử.

POST

/api/auth/login

Request

```
{ "email": "admin@example.com",  
  "password": "*****" }
```

Server response

200

```
{  
  "tokenType": "Bearer",  
  "expiresAt": "2026-09-14T...Z",  
  "user": { "vaiTro": "Admin" }  
}
```

Hình 1. Đăng nhập Admin thành công và nhận access token JWT

GET

/api/auth/me

Request

```
Authorization: Bearer <accessToken>
```

Server response

200

```
{  
  "maNgDung": "...",  
  "email": "admin@example.com",  
  "hoTen": "Quản trị viên",  
  "vaiTro": "Admin"  
}
```

Hình 2. Kiểm tra thông tin người dùng từ JWT

POST

/api/auth/logout

Request

Authorization: Bearer <accessToken>

Server response

200

{ "message": "Đăng xuất thành công." }

Hình 3. Đăng xuất và thu hồi phiên hiện tại

GET

/api/auth/me

Request

Authorization: Bearer <token đã đăng xuất>

Server response

401

Error: Unauthorized
www-authenticate: Bearer

Hình 4. Token cũ bị từ chối sau khi đăng xuất

GET

/api/access-check/warehouse

Request

Role claim: QuanLyKho

Server response

200

{ "message": "Bạn có quyền Quản lý kho." }

Hình 5. Đúng vai trò được phép truy cập

GET

/api/access-check/admin

Request

Role claim: QuanLyKho

Server response

403

Error: Forbidden

Hình 6. Đăng nhập nhưng thiếu quyền nhận 403 Forbidden

POST

/api/danh-muc

Request

```
{ "tenDanhMuc": "Điện thoại",  
  "moTa": "Các sản phẩm điện thoại",  
  "trangThai": true }
```

Server response

201

```
{  
  "maDanhMuc": 1,  
  "tenDanhMuc": "Điện thoại",  
  "trangThai": true  
}
```

Hình 7. Admin tạo danh mục thành công

POST

/api/danh-muc

Request

```
{ "tenDanhMuc": "Điện thoại", "trangThai": true }
```

Server response

409

```
{  
  "title": "Tên danh mục đã tồn tại.",  
  "status": 409  
}
```

Hình 8. Từ chối tên danh mục trùng

POST

/api/danh-muc

Request

```
{ "tenDanhMuc": " ", "trangThai": true }
```

Server response

400

```
{  
  "title": "One or more validation errors occurred.",  
  "status": 400,  
  "errors": { "TenDanhMuc": ["Tên danh mục không được để trống."] }  
}
```

Hình 9. Kiểm tra dữ liệu đầu vào không hợp lệ

GET

/api/danh-muc/0

Request

```
Authorization: Bearer <Admin token>
```

Server response

404

```
{  
  "title": "Không tìm thấy danh mục.",  
  "status": 404  
}
```

Hình 10. Truy vấn danh mục không tồn tại

III. Đánh Giá Phối Hợp & Kết Quả Chung

- + Độ tương thích: Các thay đổi tuân theo cấu trúc phân lớp API - Core - Infrastructure sẵn có. Entity và cấu hình EF Core khớp với bảng SQL Server; tên quyền được gom về một nguồn RoleNames dùng chung, tránh khai báo trùng lặp giữa controller và service.
- + An toàn xác thực: Mật khẩu chỉ được lưu dạng BCrypt. JWT được ký và kiểm tra đầy đủ Issuer, Audience, thời hạn và thuật toán. Việc kiểm tra phiên trong database giúp đăng xuất có hiệu lực ngay và phản ánh thay đổi trạng thái tài khoản/quyền.
- + Chất lượng dữ liệu: API danh mục xử lý đúng validation, unique constraint và foreign key. Cơ sở dữ liệu sử dụng transaction, ràng buộc và sổ giao dịch kho nhằm hạn chế sai lệch dữ liệu nghiệp vụ.
- + Tiến độ: Toàn bộ mục tiêu trong ngày đã hoàn thành. Dự án build thành công với 0 lỗi, 0 cảnh báo; 69/69 kiểm thử HTTP đạt; dữ liệu kiểm thử đã được dọn sạch; mã nguồn đã được đồng bộ lên GitHub.
- + Kế hoạch ngày tiếp theo: Xây dựng API quản lý sản phẩm, kho và nhà cung cấp; triển khai luồng nhập hàng/đơn bán; bổ sung quản lý người dùng cho Admin; chuẩn bị dữ liệu lịch sử và mô hình dự báo doanh số.

Link Source: <https://github.com/tienthanh-2105/SalesForecastSystem>

Commit xác thực, phân quyền và kiểm thử: a04530a